ANTHROP\C

ANTHROPIC, PBC

INDEPENDENT SERVICE AUDITOR'S SOC 3 REPORT

FOR THE

AI SERVICES

FOR THE PERIOD OF OCTOBER 1, 2024, TO SEPTEMBER 30, 2025

Attestation and Compliance Services

schellman
Quality, above all.

Proprietary & Confidential
Unauthorized use, reproduction, or distribution of this report, in whole or in part, is strictly prohibited.

schellman

INDEPENDENT SERVICE AUDITOR'S REPORT

To Anthropic, PBC:

Scope

We have examined Anthropic, PBC's ("Anthropic") accompanying assertion titled "Assertion of Anthropic Service Organization Management" ("assertion") that the controls within Anthropic's AI Services system ("system") were effective throughout the period October 1, 2024, to September 30, 2025, to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, confidentiality, and privacy (applicable trust services criteria) set forth in TSP section 100, Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria).

Anthropic uses various subservice organizations for cloud hosting services. The description of the boundaries of the system indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Anthropic, to achieve Anthropic's service commitments and system requirements based on the applicable trust services criteria. The description of the boundaries of the system does not disclose the actual controls at the subservice organizations. Our examination did not include the services provided by the subservice organizations, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

Service Organization's Responsibilities

Anthropic is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved. Anthropic has also provided the accompanying assertion about the effectiveness of controls within the system. When preparing its assertion, Anthropic is responsible for selecting, and identifying in its assertion, the applicable trust services criteria and for having a reasonable basis for its assertion by performing an assessment of the effectiveness of the controls within the system.

Service Auditor's Responsibilities

Our responsibility is to express an opinion, based on our examination, on whether management's assertion that controls within the system were effective throughout the period to provide reasonable assurance that the service organization's service commitments and systems requirements were achieved based on the applicable trust services criteria. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether management's assertion is fairly stated, in all material respects. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

Our examination included:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements.
- Assessing the risks that controls were not effective to achieve Anthropic's service commitments and system requirements based on the applicable trust services criteria.
- Performing procedures to obtain evidence about whether controls within the system were effective to achieve Anthropic's service commitments and system requirements based on the applicable trust services criteria.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Inherent Limitations

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Opinion

In our opinion, management's assertion that the controls within Anthropic's AI Services system were effective throughout the period October 1, 2024, through September 30, 2025, to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved based on the applicable trust services criteria is fairly stated, in all material respects.

Schellman & Company, LLC

Tampa, Florida
November 12, 2025

Assertion of Anthropic Service Organization Management

We are responsible for designing, implementing, operating, and maintaining effective controls within Anthropic, PBC's ("Anthropic") AI Services system ("system") throughout the period October 1, 2024, to September 30, 2025, to provide reasonable assurance that Anthropic's service commitments and system requirements relevant to security, availability, confidentiality, and privacy were achieved. Our description of the boundaries of the system is presented below and identifies the aspects of the system covered by our assertion.

We have performed an evaluation of the effectiveness of the controls within the system throughout the period October 1, 2024, to September 30, 2025, to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, confidentiality, and privacy (applicable trust services criteria) set forth in TSP section 100, *Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria)***.** Anthropic's objectives for the system in applying the applicable trust services criteria are embodied in its service commitments and systems requirements relevant to the applicable trust services criteria. The principal service commitments and system requirements related to the applicable trust services criteria are presented below.

There are inherent limitations in any system of internal control, including the possibility of human error and the circumvention of controls. Because of these inherent limitations, a service organization may achieve reasonable, but not absolute, assurance that its service commitments and system requirements are achieved.

We assert that the controls within the system were effective throughout the period October 1, 2024, to September 30, 2025, to provide reasonable assurance that Anthropic's service commitments and systems requirements were achieved based on the applicable trust services criteria.

Description of the Boundaries of the AI Services System

Company Background

Anthropic is an artificial intelligence (AI) company and public-benefit corporation (PBC), founded in 2021. Anthropic specializes in developing general AI systems and language models, with a company ethos of responsible AI usage. The company was created with the goal of building beneficial AI aligned with human values and priorities. Anthropic uses a technique called Constitutional AI to train language models via natural language feedback to be helpful, harmless, and honest. The company translates their research into tangible, practical tools, to benefit businesses, nonprofits, civil society groups, as well as people around the globe.

Description of Services Provided

Anthropic's AI services are provided via their own AI assistant, Claude. Anthropic's web-based and native applications consist of a chat interface that allows users to interact with Claude via natural language. Claude is geared to help customers with tasks such as processing text, engaging in dialogue, and handling a wide variety of instructions and logical scenarios.

Anthropic also provides an Application Programming Interface (API) that can be integrated into customer applications or cloud environments via the Anthropic API service. The Anthropic Console is available for clients to access and manage their API keys. Users interact with the API via the POST method and authenticate using secret API keys. The POST method is designed to send loads of data to a server from a specified resource.

Anthropic processes AI assistant and API calls using its cloud-hosted machine learning (ML) inference infrastructure and returns the generated response in a streaming manner via Server-Sent Events (SSE). Console prompts and responses are sent over hypertext transfer protocol secure (HTTPS) / transport layer security (TLS). Console users are authenticated using OAuth, meaning that no user login credentials are stored on Anthropic's end.

Alternatively, customers may use API-based access to Anthropic's models hosted within their own trust boundary on Google Vertex or Amazon Bedrock. Google Vertex and Amazon Bedrock users are authenticated using Google or Amazon's identity and access management (IAM) systems under the customer's control. Notably, Anthropic is unable to access prompts or responses sent via these services.

System Boundaries

A system is designed, implemented, and operated to achieve specific business objectives in accordance with management-specified requirements. The purpose of the system description is to delineate the boundaries of the system, which includes the services outlined above and the five components described below: infrastructure, software, people, procedures, and data.

Principal Service Commitments and System Requirements

Anthropic designs its processes and procedures related to the AI Services system to meet its objectives for its services. Those objectives are based on the service commitments that Anthropic makes to user entities, the laws and regulations that govern the provision of the AI Services, and the financial, operational, and compliance requirements that Anthropic has established for the services. The AI Services system is subject to the relevant regulatory, industry, and data security requirements in which Anthropic operates.

Security, availability, confidentiality, and privacy commitments to user entities are documented and communicated in service level agreements (SLAs) and customer contracts. The principal commitments are standardized and include the following:

Security

- The use of reasonable logical safeguards to grant system access only to authorized personnel.
- The use of incident response procedures to identify and remediate security incidents and events.

Availability

- The use of monitoring systems to monitor security events.
- The use of disaster recovery procedures to recover and restore data.

Confidentiality

- The use of confidentiality statements that employees are required to acknowledge.
- The use of defined customer data storage requirements.

Privacy

- The use of collection, use, retention, and destruction procedures for personal information.

Anthropic establishes operational requirements that support the achievement of the principal service commitments, relevant laws and regulations, and other system requirements. This includes using encryption technologies to protect system user data at rest and in transit, performing vulnerability scanning and penetration testing, authenticating personnel using strict enforcement mechanisms, revoking access to personnel upon termination, and ongoing monitoring to ensure the achievement of the related objectives.

Such requirements are communicated in Anthropic's SLAs and customer contracts. Information security policies define an organization-wide approach to how systems and data are protected. These include policies around how the service is designed and developed, how the system is operated, how the internal business systems and networks are managed and how employees are hired, trained, and managed. In addition to these policies, training courses have been developed to educate personnel on how to carry out specific activities and manual processes required in the operation and development of its AI Services.

In accordance with the assertion and the description criteria, the aforementioned service commitments and requirements are those principal service commitments and requirements common to the broad base of users of the system and may therefore not fully address the specific service commitments and requirements made to all system users, in each individual case.

Infrastructure and Software

The infrastructure and software supporting the Anthropic AI Services system are maintained at third-party data center facilities operated by Alphabet, Inc. (GCP) and by Amazon Web Services, Inc. (AWS). Anthropic does not own or maintain hardware located at GCP or AWS and operates under a shared security responsibility model, where GCP and AWS are responsible for the security of the underlying cloud infrastructure (i.e. physical infrastructure, geographical regions, availability zones, edge locations, components from the host operating system, and virtualization layer and storage) and Anthropic is responsible for securing the platform deployed in GCP and AWS (i.e. customer data, applications, identity access management, guest operating system, network, virtual firewall, network traffic, and server-side encryption). Anthropic maintains a zero-trust security model and access is facilitated solely through authentication and not implicitly due to network connection, location, or status.

Claude AI & Anthropic API

The Claude AI and Anthropic API systems are hosted on a serverless Kubernetes infrastructure within Anthropic's cloud environments. Container orchestration systems (Kubernetes) are used to handle and manage incoming API requests. Load balancers are used to distribute incoming traffic to the frontend instances equipped with internal application load-balancers, balancing traffic to containers. Autoscaling is enabled to optimize performance and provide efficient use of compute resources while ensuring high availability and scalability of Claude services. Private IP addresses are recursed so that they can only be reached within the Virtual Private Cloud (VPC). Network security services restrict Domain Name System (DNS) resolution through DNS filtering and recursive resolver

controls. Database services are used to store client data, model training data, and model weights, and provide production workloads with critical support functions such as caching, session management, and message brokering. Container images are stored in the private artifact management instance.

Research & Development (R&D)

The R&D environments are logically separated within GCP and AWS, to help ensure isolation from production resources. There is no ingress or egress path available for any external networks without the use of Anthropic's zero-trust networking tool. These systems facilitate the development and deployment of Anthropic's AI Services and its supporting containerized components for distribution by Anthropic's business partners, such as Google Vertex and Amazon Bedrock. Container images are stored in private container repositories.

The in-scope infrastructure consists of multiple systems as shown in the table below:

Primary Infrastructure	
Production System	**Business Function Description**
IAM	Used to manage access to services and resources, including the creation and management of users and groups, and use of permissions to allow and deny their access to resources.
Compute	Used for application delivery and to run code.
Databases	Used to store, retrieve, and manage data input into the system.
Storage System	Used to store and retrieve file data, including files uploaded by customers.
Firewall System	Protects the network perimeter and production environment and limits inbound and outbound access.

People

The roles and responsibilities of key functional leadership include the following:

- Chief Executive Officer (CEO): The CEO leads the development and execution of the company's long-term strategy. The CEO is ultimately responsible for vision setting, fundraising, closing key deals with external parties, as well as U.S. government relations.
- President: The President is responsible for overseeing people functions, providing business guidance, and acting as the company's operations principal. As part of this role, they provide cultural leadership and set the standards for operational excellence, recruitment, and retention of qualified staff. The President also currently manages operational and engineering leaders.
- Chief Information Security Officer (CISO): The CISO oversees strategic, operational, and budgetary aspects of data management and protection. This role works closely with fellow executives to develop information security policies and procedures for the organization. The CISO is the senior level executive responsible for establishing and maintaining the enterprise vision, strategy, and program to ensure information assets and technologies are adequately protected.
- General Counsel: The General Counsel provides legal advice and services to the organization. The General Counsel ensures company practices are compliant with any relevant data privacy and information security laws and regulations (e.g., GDPR, CCPA) and adhere to company adopted information security and data privacy standards and frameworks.
- Chief Science Officer (CSO): The CSO leads the company's research agenda and oversees the development of foundational AI models and capabilities. The CSO is responsible for setting the scientific direction of the organization, guiding technical research priorities, and ensuring that safety and alignment considerations are integrated into model development.

The roles and responsibilities of key functional teams include the following:

- Security Compliance: The team is responsible for understanding security and AI safety expectations as established by regulators, customers, and emerging industry norms. They provide direction to internal partners on the priorities of security and safety requirements and assure regulators and customers that these expectations are met by earning security certifications and attestations and responding to inquiries about Anthropic's security program.
- Safeguards: The team ensures the responsible and secure use of AI by enforcing policies, managing user reports, and handling account actions. They investigate threats, detect abuse, and conduct safety evaluations to mitigate risks before deploying new models. Their work helps maintain AI integrity by monitoring emerging harms, preventing misuse, and ensuring compliance with safety standards.
- Observability: The team is responsible for monitoring and analyzing the performance and behavior of AI systems to ensure their reliability, safety, and interpretability. This involves developing tools and methodologies to track system metrics, detect anomalies, and provide insights into the internal workings of AI models.
- Security Engineering: The team secures AI systems by developing critical security infrastructure and implementing secure development practices. They design and enforce cloud security architectures, including IAM, network segmentation, and encryption controls. Additionally, they conduct security architecture reviews, threat modeling, and vulnerability assessments to identify and mitigate risks, ensuring the safety and trust of users and society at large. They also develop solutions to monitor for threats, investigate incidents, and coordinate response efforts with other teams.

Procedures

Access Authentication and Authorization

Access and authorization into networks hosting Anthropic services are managed through Anthropic's access control system. User identities are verified to meet the requirements of the role being requested and contain membership in the central identity provider's (IdP) access group. A combination of least privilege, time-limited access, and a zero-trust solution are used to authorize and authenticate users' remote access to the networks. Network management sessions are secured using Secure Shell (SSH) connections, with device-bound SSH keys stored in a secure enclave. Multi-factor authentication (MFA) is enforced using hardware tokens before granting access to company assets, ensuring an additional layer of security.

Internal networks are protected by cloud-native firewalls configured with deny-by-default routing and combined instance-level and network-level rules. HTTP requests are also protected by either firewalls or network security services based on the service and function. The firewall rules and WAF configurations are configured and modified by members of dedicated security teams.

Each in-scope system component is configured to authenticate users with a unique user account and enforce predefined user account and minimum password requirements. Users are required to verify their identities using a secondary factor prior to utilizing the self-service password reset portal. Role-based permissions are used to restrict access to the in-scope systems. Identities and permissions are controlled within the centralized IdP which facilitates the provisioning of user accounts by limiting the permissions and access rights granted to personnel to pre-authorized birthright access.

Administrators of the cloud management consoles are restricted to personnel commensurate with their job role.

Access Requests and Access Revocation

Documented policies and procedures are in place to guide personnel in administering user access. User administration processes for IT systems and applications are tied to the new hire, termination, and role change processes established by Anthropic. Internal IT access requests are approved by management prior to granting access to systems or privileges not included in the user's default birthright access.

Accounts assigned to terminated users are automatically disabled when their employment status is updated in the HRIS. Terminations are revoked manually and immediately upon notification to IT personnel by HR representatives.

HR representatives coordinate the collection of physical company assets. Checklists are used to guide the task owners through each step in the onboarding and termination process.

A user access review process for privileged user groups is conducted on a quarterly basis for the in-scope systems. The process is facilitated by system owners who pull a listing of users and review the listing to ensure access was appropriate based on least privilege. Additionally, a stale user account process is automated to alert on stale accounts that have not been accessed in a pre-defined period of time. Stale accounts are escalated to the People and Operation department, who will reach out to system owners to remove access if access is no longer necessary.

Device and Network Security

Network and data flow diagrams are utilized to illustrate the segmentation boundaries and communication paths between system resources. Network Security Controls (NSCs) are configured to deny traffic from external sources and only allow specific services to a specific destination. Host-based firewalls are configured on workstations to filter out unauthorized traffic. Access to administer the firewalls is restricted to personnel commensurate with their job roles and responsibilities. Changes to firewall rules follow the code review process prior to implementing new rules. Firewall rules are reviewed at least annually to ensure that rules are optimized to mitigate risks from external sources and communication paths have a business justification.

Anthropic enforces a security baseline on the in-scope workstations and device-based access controls such as minimum password complexity requirements, drive encryption, and a 10-minute inactivity timeout configuration that requires users to re-authenticate thereafter. Geo-blocking technology is enforced on endpoints to disallow access from high-risk locations.

The MDM platform requires the installation of an endpoint detection and response (EDR) agent as a component of the security baseline. Among other capabilities, the EDR platform provides antivirus, antimalware, and antispyware, and prevents read and write access to removable mass storage devices. The MDM platform provides the capability to remotely wipe devices in the event of loss or theft and enforces an application allow list, which prevents users from installing and running applications not found on a pre-defined, trusted application list and containing unauthorized binaries.

Anthropic also uses Google Workspace as a device management tool for network level enforcement of password complexity and protection of mobile devices such as encryption and remote wipe. Anthropic makes use of Google Context Aware Access (CAA) to enforce user identity and device security controls, including additional unique authentication and access procedures and geofencing capabilities. Google CAA also checks conditional access policies to ensure that each workstation accessing the system is compliant with the defined security baseline before allowing access.

Change Management

Documented change management policies and procedures, including the secure development policy, are in place to guide personnel in the authorization, testing, approval, and implementation of changes into the production environment. These policies cover changes to the infrastructure, software, or applications. A change management ticketing system is utilized to facilitate and document the change management process. A code repository and versioning software is used to track and monitor changes to scripts and source code used to provision, update, or deploy services and applications on production servers. Additionally, the source code versioning software allows for the ability to roll back changes that were deployed.

The source code repository has a protected main branch with gated branch protections to systematically enforce the requirements set forth by management. Only designated code owner groups have the ability to merge pull requests to the main branch. The repository is configured to prevent changes from being promoted without review from an authorized approver. Code vulnerability scanning is completed using static application security testing (SAST) tools.

QA testing is performed for application changes prior to deployment to the production environment. Testing of development changes is performed in a staging environment prior to deployment into production. Development and QA testing environments do not use or contain customer data, and are logically separate from the production environment. Application code and infrastructure changes are approved prior to deployment to the production environment to ensure the changes are functioning as designed without unintended results.

Once QA testing has been completed and approval has been given, the change is promoted to the production environment. Access to deploy changes into the production environment is restricted to personnel commensurate with their job role.

The organization follows a structured patch management process to address known vulnerabilities and ensure that the software versions in use remain within the supplier's supported lifecycle. Patch management software is utilized to monitor current patch levels of endpoints and ensure systems are protected. Management takes a risk-based approach to prioritize security patches. Security patches are tested in a small group of endpoints before they are rolled out to the rest of the environment by system administrators. Critical updates have larger testing groups and are inclusive of system owners to ensure system functionality prior to deploying the patch.

The MDM tool manages workstation patch levels by enforcing policies that will require updates within a predefined time period. Google CAA monitors at the IdP layer to check that workstations' operating systems are up to date and within the security baseline before allowing access. Containers are patched by updating and redeploying the service using the latest container images. Anthropic follows an ephemeral node strategy, ensuring that outdated nodes are systematically decommissioned and replaced with fully updated instances. Each new node is provisioned with the latest security patches as provided by the respective cloud environment, minimizing the risk of vulnerabilities associated with outdated software.

Trusted, verified, and signed base images are sourced to mitigate the risk of introducing known vulnerabilities into containerized environments. During the development phase, container images are stored and managed in an artifact management system. Container images are re-scanned whenever the vulnerability database is updated. Changes made to container images are required to adhere to the change control process. This process includes sufficient testing and management approval before builds are migrated to the cloud repositories. Kubernetes services are configured to enforce the use of builds published exclusively to the container registries, ensuring controls over the development process cannot be circumvented.

Data Backup and Disaster Recovery

Backup and recovery policies and procedures are documented to guide personnel in backup activities including performing, retaining, and testing backups. An automated job scheduler is configured to perform backups daily on production databases and storage buckets to ensure that confidential company information is available. Backups are encrypted and stored separate from where the primary data source resides. The backup system is configured to retain daily backups for 30 days. Additionally, replication technologies are in place to provide protection against data loss and service disruptions.

Anthropic maintains a disaster recovery plan and utilizes built-in redundancies provided by GCP and AWS to minimize or prevent downtime in case of an adverse event occurring. This plan is available to guide personnel in the event of unexpected disruption in operations. The DR plan defines recovery roles and responsibilities, notification requirements, critical systems and processes, and the recovery time objectives necessary. Anthropic personnel that are involved with disaster recovery and availability functions participate in testing of the disaster recovery plan on an annual basis to ensure service commitments can continue to be met. The results of the exercise are documented and incorporated in the annual review and update of the plan.

Incident Response

A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents. Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches. Suspected security incidents are reported through the IT systems, which also monitor and track reported security incidents from identification to resolution.

To respond to an intrusion or incident, predetermined teams are assigned to resolve the issue depending on the incident's characteristics. Incidents are handled at the lowest appropriate escalation level to reduce the total impact and maximize use of available technical resources. If the expected impact of an incident is determined to be of a higher significance, alternative technical teams are called upon to contribute to the incident response resolution. As the impact of an incident becomes more significant or widespread, the escalation level increases and additional resources are assigned to the incident to address the problem as needed. In the event a breach or unauthorized use of data occurs, notice is provided to the affected parties. An assessment of major incidents is performed through root-cause analysis to prevent similar incidents in the future. The incident response plan is tested annually during a tabletop meeting to ensure efficiency and identify any potential gaps.

System Monitoring

Anthropic uses logging and monitoring systems to monitor potential security threats and vulnerabilities as well as system performance and resource utilization. Intrusion detection software is also in place to detect any unusual system activity or access attempts. Users are assigned a unique username, such that individual activities within the system are restricted, logged, and monitored.

Anthropic utilizes centrally managed enterprise tools for log aggregation, threat detection, and resource health monitoring. The security information and event management (SIEM) platform provides threat detection and facilitates the response process by aggregating logs from endpoints and cloud environments. A separate monitoring tool is used for logging uptime and availability metrics. Critical alerts trigger notifications through an alerting and on-call management system to on-call personnel, and messages are sent via internal communication channels to alert appropriate team members. The scope of aggregated logs is reviewed and updated annually to ensure that sufficient information is being logged. Access to audit logs is restricted to personnel commensurate with their job role. CAA controls are enabled to prevent unauthorized or non-compliant devices from accessing the organization's resources. This configuration also allows for geo-blocking capabilities to prevent users from accessing the in-scope environment from high-risk locations.

Management also maintains an asset inventory to establish where confidential information is being recorded as well as to assist with identifying vulnerabilities and establishing accountability of assets.

Anthropic's vulnerability management program is designed to identify, assess, and remediate identified security vulnerabilities across the environment. EDR software is used to scan endpoints for malicious software and activity. Containers are scanned for vulnerabilities upon pushing to the registry by native container scanning capabilities provided by the cloud platform. In addition to container repository scanning, code vulnerability scanning is completed via SAST tools, which runs on a scheduled cadence to continuously monitor the codebase for vulnerabilities.

Anthropic utilizes an automated vulnerability scanning system to identify weaknesses and vulnerabilities within the production systems. The scanning system is configured to alert personnel to identified vulnerabilities. Personnel receive alerts through internal messaging and paging systems in accordance with the severity of the detected vulnerability.

The organization conducts third-party penetration tests and regular red team exercises to assess its security posture and incident response capabilities. These assessments simulate real-world attack scenarios to identify vulnerabilities in networks, applications, and infrastructure.

Vulnerabilities that are identified from the above methods are assigned a severity level from Critical through Low with Critical being the highest level of severity. The relevant stakeholders are notified upon identification and are assigned a remediation task through the ticketing system. Remediation timeframes are defined by management for each severity level.

Privacy Practices

As a component of Anthropic's AI Services system, Anthropic provides services to commercial user entities as a data processor. Anthropic serves in the function of a data processor in cases where it processes personal data as instructed by users (data controllers) in order to fulfill the requirements of an agreement associated with the provisioning of the services. Additionally, Anthropic retains customer personal information for the duration of the active contract. Customer data is deleted at the instruction of the data controller's instructions and/or upon request, using Anthropic's automated tool.

User entities are responsible for providing their privacy notice to individuals. Anthropic communicates its Commercial Terms of Service and Privacy Policy to commercial users through the website. The Commercial Terms of Service and Data Processing Addendum (DPA) outline how long and for which situations user data will be stored. Production data is not used in testing environments unless there is an agreement in place for fine-tuning of a specific model being used on a per client basis.

Comprehensive information security and privacy programs are maintained that document technical and organizational safeguards designed to ensure customer data is not lost, accidentally destroyed, misused, or disclosed, and is not accessed except by authorized employees and partners in the performance of their duties.

Anthropic maintains a privacy program with support from the Safeguards, Observability, Legal, and Security Engineering teams, who provide oversight, guidance, and coordination to ensure alignment with applicable privacy regulations and safety programs. To strengthen the privacy program, data privacy impact assessments (DPIAs) are performed as changes are made or reviewed annually to assess risks based on privacy and security of personal data being stored and processed. A separate impact assessment is completed for the regions in which Anthropic does business. Additionally, a record of processing activities (ROPA) is maintained to help verify that personal information is collected, used, maintained, and processed in a manner consistent with the entity's objectives related to privacy.

Anthropic customers are responsible for ensuring that (i) they will comply with all applicable data protection legislation and (ii) they have the right to transfer, or provide access to, the personal data to Anthropic for processing in accordance with the terms of the agreement.

Anthropic tracks unauthorized disclosures of personal information. In the event of complaints, disputes, or data deletion requests, Anthropic has dedicated privacy and Data Protection Officer (DPO) e-mail accounts and resolution processes in place.

Data

Anthropic maintains policies and procedures for data management to guide personnel in the classification, handling, retention, and disposal of data. Anthropic utilizes a risk-based approach when granting access to data and restricts access on a need-to-know basis. The data classification procedures define the risk classifications of information. Information is classified into one of the three broad categories below:

- Confidential Need to Know (NTK): Anthropic proprietary information requiring thorough protection; access is restricted to employees with a "need-to-know" based on business requirements. This data can only be distributed outside the company with a nondisclosure agreement (NDA) and approval.
- Confidential: Information not intended for public distribution but can be shared among employees. Confidential information may also be shared outside the company with an NDA and approval.
- External: Documents intended for public consumption which can be freely distributed outside Anthropic.

Anthropic encrypts data both in transmission and while at rest regardless of where it is stored. The organization employs strong cryptographic modules, ensuring the protection of its clients' data and secure communication channels. GCP- and AWS-managed encryption key services encrypt data stored within Anthropic's cloud environments using AES-256 or better. The data stores are accessible from external networks including those used to store client data, model training data, model weights, and access keys. Web and API requests are encrypted using TLS 1.2 or higher.

Data owners, in consultation with legal counsel, may determine retention periods for their data. Anthropic assesses the data and disposal practices of third-party vendors in accordance with the third-party management policy. Only third parties that meet Anthropic requirements for secure data disposal are used for storage and processing of restricted or confidential data.

The disposal of data and media is tracked internally to maintain an audit trail. Anthropic retains data as long as the company has a need for its use, or to meet regulatory or contractual requirements. Once data is no longer needed, it is securely disposed of or archived. Retiring physical media assets, such as employee workstations, requires a destruction declaration to be retained and follow industry best practices (e.g. shredding and incineration).

Significant Changes During the Period

There were no significant changes that are likely to affect report users' understanding of how the in-scope system is used to provide the services covered by this examination during the period.

Subservice Organizations

The cloud hosting services provided by Google and AWS were not included within the scope of this examination. The following table presents the applicable Trust Services criteria that are intended to be met by controls at Google and AWS, alone or in combination with controls at Anthropic, and the types of controls expected to be implemented at Google and AWS to meet those criteria.

Ref.	Control Activities Expected to be Implemented by GCP and AWS	Applicable Trust Services Criteria
CSOC.1	GCP and AWS are responsible for implementing controls to manage logical access to the underlying network and virtualization management software for their cloud hosting services where production systems reside.	CC6.1 – CC6.3 CC6.6 – CC6.7
CSOC.2	GCP and AWS are responsible for implementing controls to restrict physical access to facilities and protected information assets.	CC6.4
CSOC.3	GCP and AWS are responsible for implementing controls to render data unreadable, when directed by Anthropic, prior to the decommissioning of physical assets.	CC6.5
CSOC.4	GCP and AWS are responsible for implementing controls to protect against environmental vulnerabilities and changing environmental conditions.	A1.2

Complementary User Entity Responsibilities

Anthropic's controls are designed to provide reasonable assurance that the principal service commitments and system requirements can be achieved without the implementation of complementary controls at user entities. As a result, complementary user entity controls are not required, or significant, to achieve the principal service commitments and system requirements based on the applicable trust services criteria.

However, in order for user entities to benefit from the AI Services system and its controls, the following responsibilities should be considered by user entities:

Ref.	Control Activities Expected to be Implemented at User Entities	Related Applicable Trust Services Criteria
CUER.1	User entities are responsible for implementing controls to comply with their contractual obligations to Anthropic, including the Terms of Service and Acceptable Use Policy.	CC2.3
CUER.2	User entities are responsible for implementing controls to notify Anthropic of changes made to administrative contact information.	
CUER.3	User entities are responsible for implementing controls to ensure data submitted to Anthropic's services complies with applicable laws, regulations, and the user entity's own data governance policies.	
CUER.4	User entities are responsible for implementing controls to report issues with Anthropic's systems and platforms, including suspected security incidents or unauthorized access.	CC2.3 / CC7.2 / CC7.3 / CC7.5 / P6.3 / P6.6 / P8.1
CUER.5	User entities are responsible for implementing controls to provision, maintain, and deprovision user access in accordance with user entity's access management policies.	CC6.1 – CC6.3
CUER.6	User entities are responsible for implementing controls to safeguard authentication credentials, including API keys, from unauthorized disclosure.	CC6.1 / CC6.6

Ref.	Control Activities Expected to be Implemented at User Entities	Related Applicable Trust Services Criteria
CUER.7	User entities are responsible for implementing controls to configure available security settings, including MFA and single sign-on integrations, in accordance with the user entity's security policies.	CC6.1 / CC6.6
CUER.8	User entities are responsible for implementing controls to secure the local environments where Claude Code is executed and to review any generated or modified code prior to deployment in their environments.	CC6.1 / CC8.1

Trust Services Criteria Not Applicable to the In-Scope System

The Trust Services criteria presented below, are not applicable to the AI Services system within the scope of this examination. As a result, an associated control is not required to be in place at the service organization for the omitted applicable trust services criteria. The following table presents the trust services that are not applicable for the AI Services system at Anthropic.

Criteria #	Reason for Omitted Criteria
P1.1	Providing notice to data subjects regarding privacy practices, including changes in the use of personal information, is the responsibility of the data controller and not Anthropic given its role as a data processor.
P2.1	Communicating choice and obtaining consent regarding the collection, use, retention, disclosure, and disposal of personal information to data subjects is the responsibility of the data controller and not Anthropic given its role as a data processor.
P3.2	Obtaining consent and communicating the need for consent, as well as the consequences of a failure to provide consent for the request for personal information, to data subjects is the responsibility of the data controller and not Anthropic given its role as a data processor.